

GdR GPL : GT LVP 2025

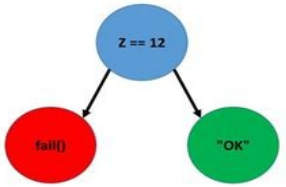
Adapter le fuzzing hybride pour l'exposition de vulnérabilités

Clément Poncelet

Bagages

Exécution Symbolique

```
1 int f() {
2   ...
3   y = read();
4   z = y * 2;
5   if (z == 12) {
6     fail();
7   } else {
8     printf("OK");
9   }
10 }
```



2013:16

IRCAM - UPMC

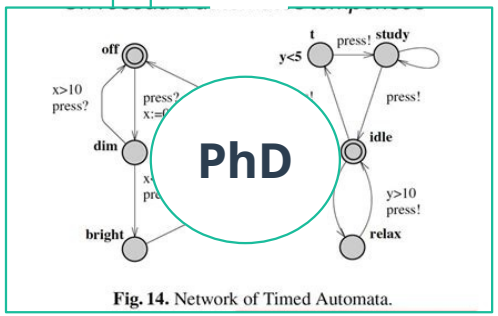


Fig. 14. Network of Timed Automata.

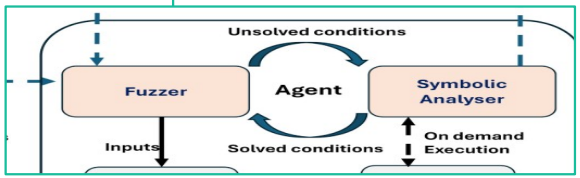
Automate temporisé

2017:18

Université de Salzbourg

2019:21

Université d'Uppsala



Fuzzeur hybride

2022:25

MTB111



RI unificatrice pour une trans-compilation sure

Adapter le fuzzing hybride pour l'exposition de vulnérabilités

2019:21 *Université d'Uppsala*

Équipe *Division of Computer Systems*



Kostis Sagonas



Nicolas Tsiftes

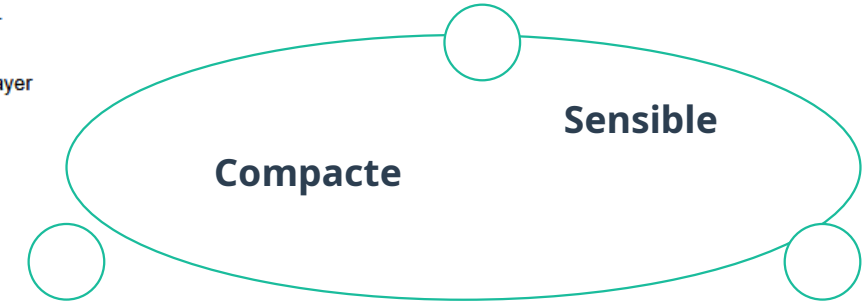
RI. SE

UPPSALA UNIVERSITET

CONTIKI NEXT GENERATION

HTTP	MQTT	CoAP	**SNMP**	Application layer
TCP		UDP / DTLS		Transport layer
IPv6		**RPL**		Network layer
		IPv6 ND		
		ICMPv6		
6LoWPAN				Adaptation layer
CSMA		TSCH		MAC layer
BLE		IEEE 802.15.4		Physical layer

IOT Network Stack



Adapter le fuzzing hybride pour l'exposition de vulnérabilités

2019:21 *Université d'Uppsala*

Équipe *Division of Computer Systems*



Kostis Sagonas



Nicolas Tsiftes

RI. SE

UPPSALA UNIVERSITET

CONTIKI NEXT GENERATION

HTTP	MQTT	CoAP	**SNMP**	Application layer
TCP		UDP / DTLS		Transport layer
IPv6		**RPL**		Network layer
		IPv6 ND		
		ICMPv6		
6LoWPAN				Adaptation layer
CSMA		TSCH		MAC layer
BLE		IEEE 802.15.4		Physical layer

IOT Network Stack

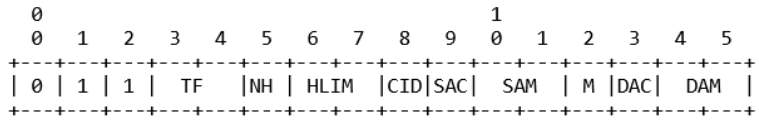


Figure 1: LOWPAN_IPHC Base Encoding (RFC 6282)

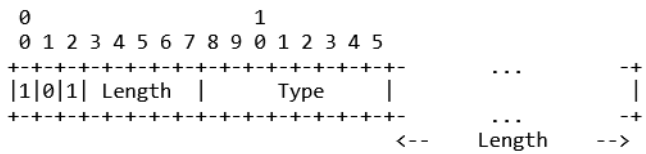
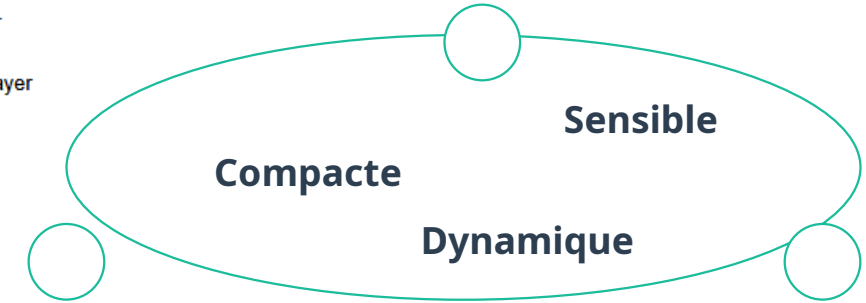


Figure 3: Elective 6LoWPAN Routing Header



Adapter le fuzzing hybride pour l'exposition de vulnérabilités

2019:21 *Université d'Uppsala*

Équipe *Division of Computer Systems*



Kostis Sagonas



Nicolas Tsiftes

RI.SE

UPPSALA UNIVERSITET

CONTIKI NEXT GENERATION

HTTP	MQTT	CoAP	**SNMP**	Application layer
CSMA		TSCH		MAC layer
BLE		IEEE 802.15.4		Physical layer

IOT Network Stack

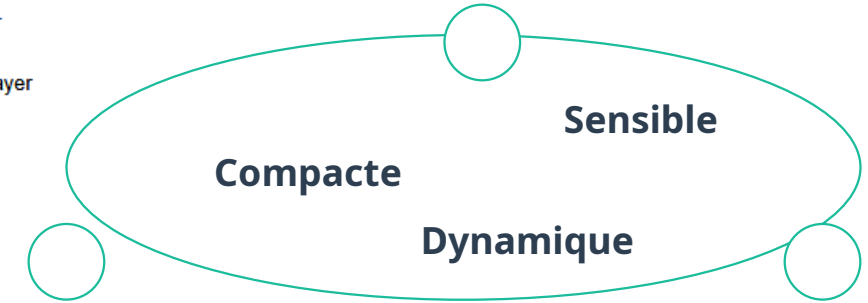
Exposer automatiquement les failles de sécurité ?

```
 0                                   1
 0   1   2   3   4   5   6   7   8   9   0   1   2   3   4   5
+---+---+---+---+---+---+---+---+---+---+---+---+---+---+---+---+
| 0 | 1 | 1 |  TF   |NH | HLIM  |CID|SAC|  SAM  | M |DAC|  DAM  |
+---+---+---+---+---+---+---+---+---+---+---+---+---+---+---+---+
```

Figure 1: LOWPAN_IPHC Base Encoding (RFC 6282)

```
 0                   1
 0 1 2 3 4 5 6 7 8 9 0 1 2 3 4 5
+-+-+-+-+-+-+-+-+-+-+-+-+-+-+-+-+       ...       -+
|1| Length  |      Type     |                       |
+-+-+-+-+-+-+-+-+-+-+-+-+-+-+-+-+       ...       -+
                                <--    Length    -->
```

Figure 3: Elective 6LoWPAN Routing Header



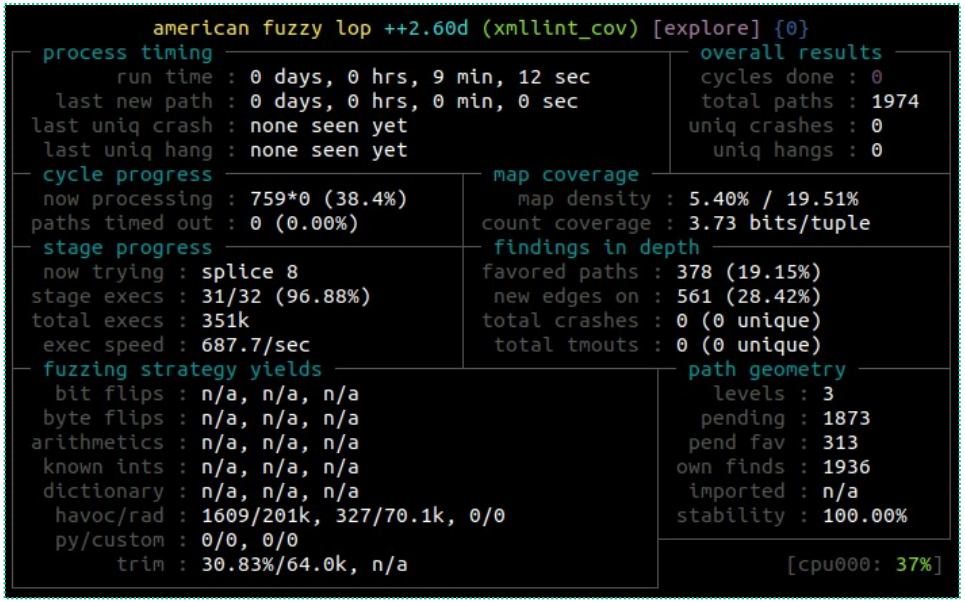
Adapter le fuzzing hybride pour l'exposition de vulnérabilités

2019:21 *Université d'Uppsala*

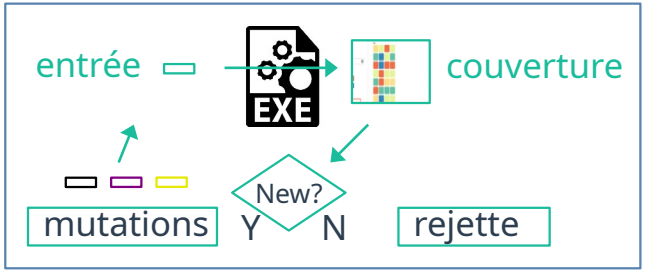
Fuzzing hybride

Test boite grise

An empirical study of the reliability of UNIX utilities (1990)



AFL : 2016



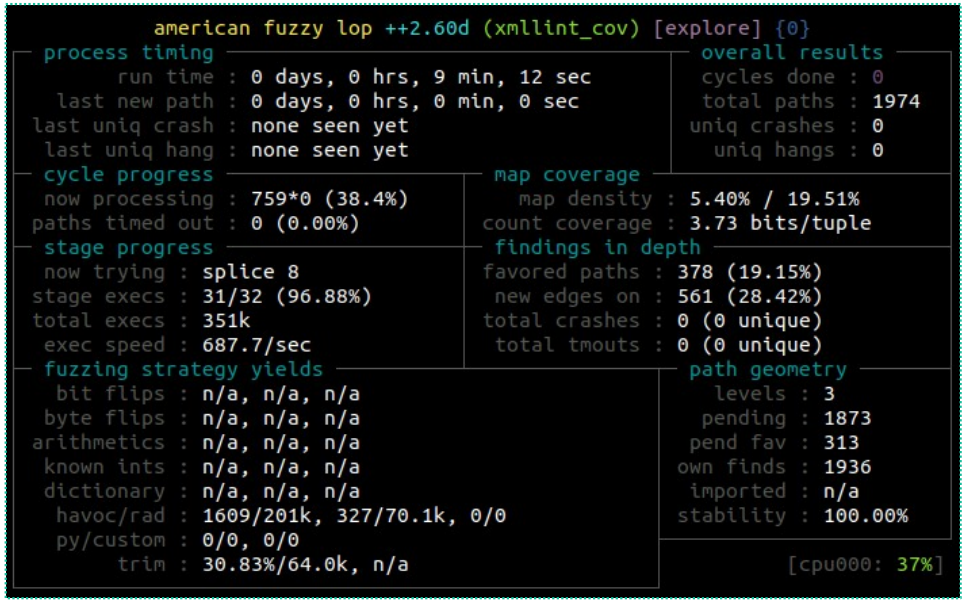
Adapter le fuzzing hybride pour l'exposition de vulnérabilités

2019:21 *Université d'Uppsala*

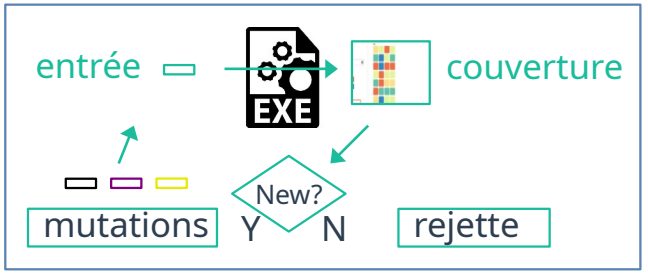
Fuzzing hybride

Test boite grise

An empirical study of the reliability of UNIX utilities (1990)



AFL : 2016



Extrêmement rapide

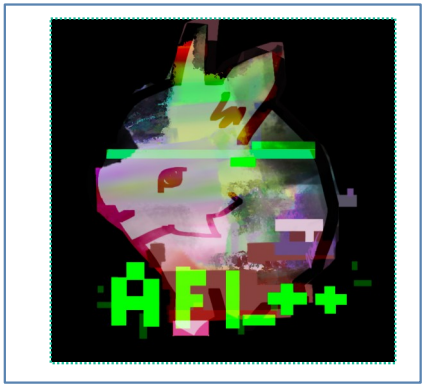
Peu profond (aléatoire)

Adapter le fuzzing hybride pour l'exposition de vulnérabilités

2019:21 *Université d'Uppsala*

Fuzzing hybride

Fuzzeurs



entrée

Analyses

Driller, QSym : *Exécution concolique*

Angora : *Analyse teintée + algo du gradient*

Intriguer : *Analyse teintée + Exécution symbolique*

SymCC : *Exécution symbolique native*

Extrêmement rapide

Peu profond

Profond et rigoureux

Adapter le fuzzing hybride pour l'exposition de vulnérabilités

2019:21 *Université d'Uppsala*


Home > Conferences > CCS > Proceedings > CCS '18 > Evaluating Fuzz Testing

RESEARCH-ARTICLE | PUBLIC ACCESS

Evaluating Fuzz Testing

Authors: George Klees, Andrew Ruef, Benji Cooper, Shiyi Wei, Michael Hicks

Authors Info & Claims

CCS '18: Proceedings of the 2018 ACM SIGSAC Conference on Computer and Communications Security

Pages 2123 - 2138 • https://doi.org/10.1145/3243734.3243804

Published: 15 October 2018 Publication History

Check for updates

Adapter le fuzzing hybride pour l'exposition de vulnérabilités

2019:21 *Université d'Uppsala*

Définition d'une « ground truth » avec notion de vulnérabilité (2 SHA gits)

Publication d'une plateforme d'évaluation statistique sur Dockers

Ajout et analyse d'impact des sanitizers (Asan ; UBSan ; EffectiveSan)

18 vulnérabilités exposées (et fixées) dans Contiki-ng



Plateforme pour évaluation de Fuzzeur Hybride

Coupler la vitesse de l'aléatoire avec des analyses de programme

Adapter le fuzzing hybride pour l'exposition de vulnérabilités

Id	AFL-clang	AFL-cf	MOPT	Angora	QSYM	Intriguer	SAVIOR	SYMCC
6LoWPAN-frag	0	1 08:50:49	1 00:11:43	0	1 00:03:15	0	-	0
SRH-param	**10** 02:13:48	0	**10** 02:30:14	7 01:21:25	**10** 00:25:01	**10** 01:29:04	-	**10** 00:09:34
ND6-overflow	0	0	0	0	1 00:26:44	0	-	0
6LoWPAN-ext-hdr	**10** 00:05:03	0	**10** 00:03:35	**10** 00:11:24	**10** 00:09:04	**10** 00:10:14	-	**10** 00:06:12
SRH-addr-ptr	**10** 02:40:11	0	9 01:24:37	9 04:40:44	9 00:51:55	**10** 02:08:22	-	**10** 00:15:36
6LoWPAN-decompr	**10** 00:00:48	0	**10** 00:00:33	**10** 00:02:09	**10** 00:01:07	**10** 00:00:50	-	**10** 00:00:20
6LoWPAN-hdr-iphc	**10** 01:58:58	0	**10** 02:26:18	**10** 07:18:57	**10** 07:26:44	**10** 04:44:29	-	9 02:14:19
6LoWPAN-UDP-hdr	0	0	0	0	0	0	-	0
6LoWPAN-payload	**10** 00:10:49	0	**10** 00:04:19	**10** 02:00:20	**10** 00:41:21	**10** 01:00:01	-	**10** 00:15:16

Adapter le fuzzing hybride pour l'exposition de vulnérabilités

Les techniques dites de fuzzing hybride sont-elles plus performantes que les fuzzeurs pour exposer des vulnérabilités?

Pas de différences significatives entre les techniques vanilla et hybrides

Mais

- Une amélioration significative en comparant à AFL (notamment des vulnérabilités non exposées avec AFL)

Adapter le fuzzing hybride pour l'exposition de vulnérabilités

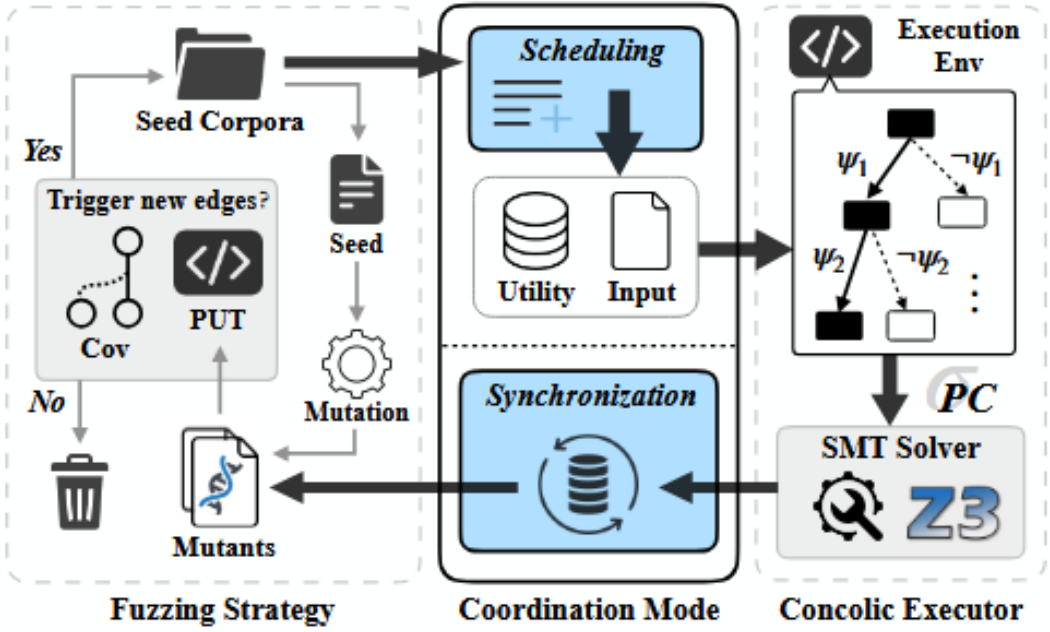
Les « sanitizers » améliorent-ils l'exposition de vulnérabilité ?

(ASan ; UBSan ; EffectiveSan)

ASAN rend le fuzzeur beaucoup plus lent et moins performant (notamment hors llvm).

Mais expose des vulnérabilités invisibles pour une méthode vanilla.

Adapter le fuzzing hybride pour l'exposition de vulnérabilités



Perspectives ?

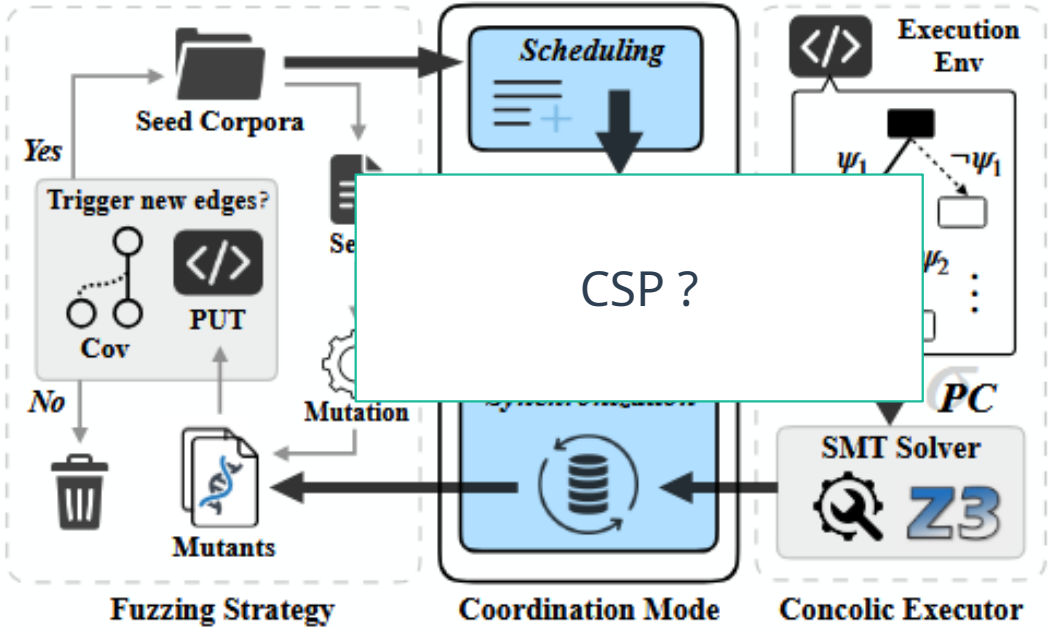
Pangolin :
Interprétation abstraite

Kluzzer :
Klee extension

CovFuzz :
Ordonnancement orienté 'edge'

[Ref : ICSE'23, Evaluating and Improving Hybrid Fuzzing]

Adapter le fuzzing hybride pour l'exposition de vulnérabilités



Perspectives ?

Pangolin :
Interprétation abstraite

Kluzzer :
Klee extension

CovFuzz :
Ordonnancement orienté 'edge'

[Ref : ICSE'23, Evaluating and Improving Hybrid Fuzzing]